



Test Strategy — TASCO Growth Platform

TASCO Insurance × VETC Growth Platform — Quality Engineering

iorta TechNXT

Version 1.0 · 07 October 2026

Contents

1. Scope
 2. Test levels and types
 3. Regression and automation strategy
 4. Environments
 5. Test data management
 6. Entry and exit criteria
 7. Defect management
 8. Metrics
 9. Roles and responsibilities
 10. Current execution results
- Appendix A — Known issues register (from code review, 07 October 2026)

Document	Version	Date	Owner	Status
Test Strategy	1.0	07 October 2026	iorta TechNXT QA Lead	Issued for submission

Item	Value
System under test	tasco-growth-platform v1.0.0 (Node.js ≥ 22.12, PostgreSQL 16 or in-memory store)
Client	TASCO Insurance, with VETC as ecosystem and channel partner
Delivery partner	iorta TechNXT
Document owner	iorta TechNXT QA Lead
Approvers	TASCO IT Head, TASCO Business Owner, TASCO Compliance, VETC IT Lead
Baseline	Aligned with the Project Plan gates G2 (build complete), G3 (go/no-go) and G4 (scale)
Related	Test Case Catalogue · Performance and Capacity Test Plan · UAT Plan · Operations index
Record of execution	TASCO-Test-Cases-and-Results.xlsx (docs/quality/TASCO-Test-Cases-and-Results.xlsx): sheets <i>Functional Test Cases</i> , <i>Test Cases</i> , <i>Automated Run</i> and <i>Summary</i> . Results of the latest run are summarised in §10

Sandbox and production. The repository ships **sandbox adapters only** for the outbound integrations: the VETC wallet, TASCO core policy administration, Zalo ZNS, SMS, app push (`src/adapters/integrations/mockGateways.js`) and the voice-AI caller (`src/adapters/integrations/simulatedCaller.js`). Synthetic VETC source data comes from `syntheticVetcSource.js` . Unit, integration, API, security and performance tests in this repository run against those sandboxes. **SIT against the real VETC, TASCO and Zalo UAT endpoints needs the production adapters**, which are on the Sprint 2–3 backlog. SIT cases are written now so they can run as soon as the adapters exist. Do not read any result in this document as evidence about real partner behaviour unless it is labelled SIT or later.

1. Scope

1.1 In scope

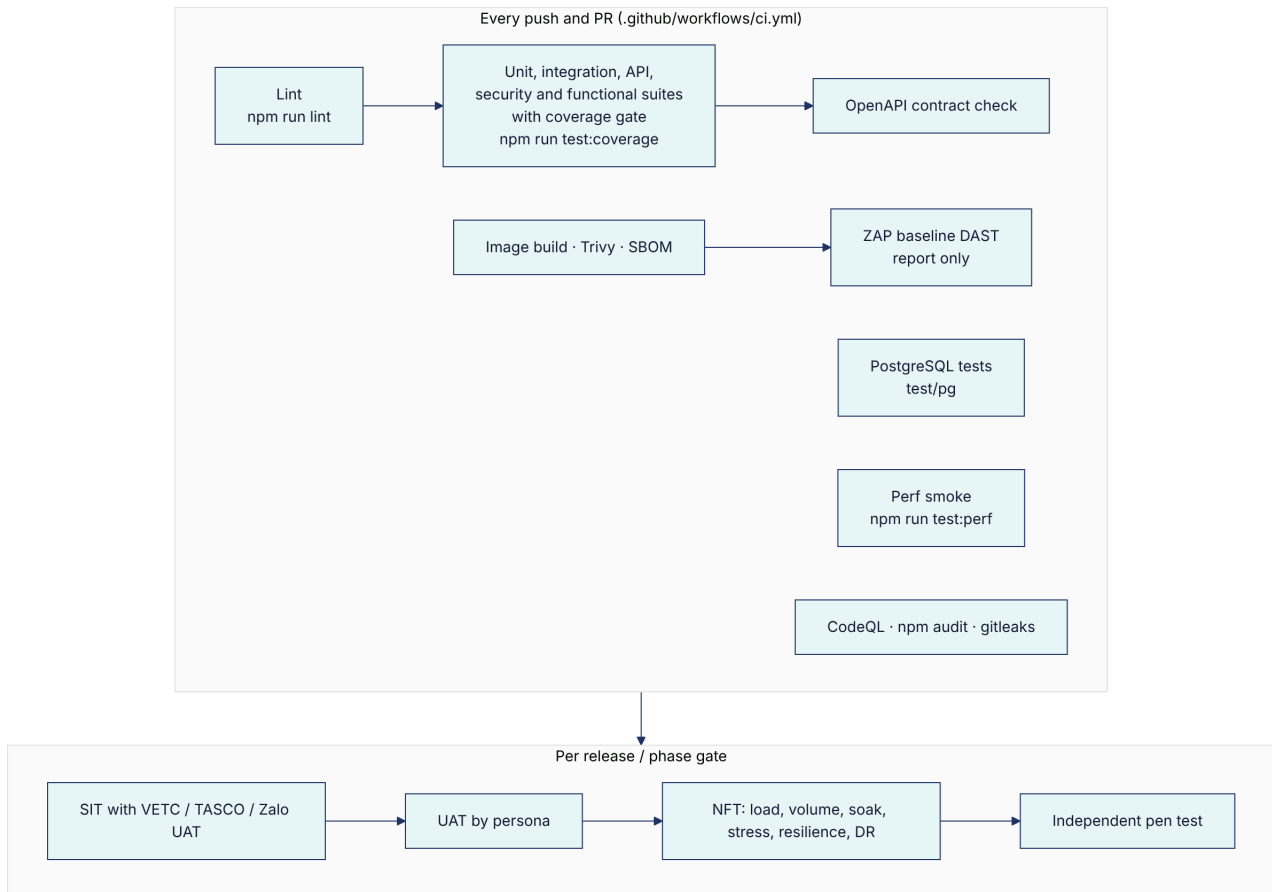
Area	Components (code)	Main risks tested
HTTP pipeline and platform	<code>src/adapters/http/app.js</code> , <code>router.js</code> , <code>security.js</code> , <code>openapi.js</code> ; <code>/health/live</code> , <code>/health/ready</code> , <code>/metrics</code> , <code>/api/openapi.json</code>	Wrong status codes, missing security headers, request-size abuse, CORS bypass, contract drift
Identity and access	<code>identityService.js</code> , <code>accessPolicy.js</code> , <code>config/security/rbac.json</code> , <code>config/rules/abac.json</code> , <code>shared/crypto.js</code>	Broken authentication, MFA bypass, privilege escalation, IDOR, PII leakage
Data enrichment and MDM	<code>ingestionService.js</code> , <code>domain/enrichment.js</code> , <code>domain/identity.js</code> , <code>config/rules/enrichment.json</code>	Wrong golden record, plate and phone normalisation errors, lost customer declarations, DQ issues not raised

Area	Components (code)	Main risks tested
Lead scoring and NBA	leadService.js, domain/leads.js, config/rules/scoring.json, nba.json, benefits.json	Mis-prioritised leads, unexplainable scores, benefits pending legal review reaching customers
Journey engine	journeyService.js, domain/contactPolicy.js, journeys.json, triggers.json, contact_policy.json, copy_guard.json, content.messages.json	Spam, contact outside 08:00–20:00 ICT, contact with DNC customers, banned discount wording, missed touchpoints
Voice bot and telesales	voiceService.js, domain/voicebot.js, content.voicebot.json; /api/voice/*, /api/handoffs/*	Plate disclosure, opt-out not honoured, wrong handoffs, agents seeing other agents' work
Sales	salesService.js, domain/rating.js, tariffs, products.json, commission.json	Wrong premium, double charge, quote reuse after expiry, payment without policy, commission above the statutory cap
Partner channel	partnerService.js, /api/partner/v1/*	Key leakage, cross-partner IDOR, unknown-plate onboarding abuse
Claims FNOL	claimsService.js	Illegal state transitions, claims against other customers' policies
Rules governance	rulesService.js, rules/validators.js, jsonLogic.js, decisionTable.js	Self-approval, invalid rule activated, cache not refreshed across replicas
Privacy and audit	customerService.js (DSAR), auditService.js, persistence/auditChain.js, persistence/codec.js	Erasure with an active policy, PII in clear at rest, audit tampering not detected
Operations	opsService.js, outboxEventBus.js, src/jobs/cli.js, src/server.js, shared/resilience.js, shared/metrics.js, shared/logger.js	Lost events, dead letters, unreconciled orders, unsafe shutdown, missing telemetry
Persistence	memoryStore.js, postgresStore.js, db/migrations/*.sql, schema.js	Adapter drift between memory and Postgres, migration failures, SQL injection
Front-ends	Staff console, customer app (/app/), public verification page (/verify/<certNo>) under public/ (UX workstream)	Accessibility, localisation, usability
Deployment assets	Dockerfile, docker-compose.yml, deploy/k8s/*, railway.json, .github/workflows/ci.yml	Image vulnerabilities, probe misconfiguration, missing CronJobs

1.2 Out of scope (tested by the owning party)

- Internal behaviour of TASCO core policy administration, the VETC wallet ledger, VETC SSO, Zalo ZNS delivery, the SMS brandname gateway and the voice-AI vendor's ASR/TTS. We test **our contract with them** in SIT, not their internals.
- Claims adjudication. The platform is the FNOL front door only.
- The TASCO enterprise IdP (Azure AD or Keycloak via OIDC, see the comment in `identityService.js`). Federation is tested in SIT once it is configured.

2. Test levels and types



2.1 Unit tests — `test/unit/*.test.js` (`npm run test:unit`)

- **Target:** pure domain and shared modules. Examples: `domain/identity.js` (plate and phone normalisation, spoken-plate extraction), `domain/enrichment.js`, `domain/leads.js` (facts, journey assignment, scoring, NBA, benefits, touchpoint planning), `domain/rating.js` (three rating methods, cover start date, commission cap), `domain/contactPolicy.js`, `domain/voicebot.js` (dialogue state machine), `rules/*` (JSON Logic, decision tables, validators), `shared/*` (crypto, validation, resilience, metrics, logger redaction, config) and `persistence/*` (codec, audit chain, query semantics, schema ↔ migration parity).
- **Runner:** `node:test` (built into Node 22). No third-party test framework, consistent with the platform's minimal-dependency policy (one runtime dependency: `pg`).
- **Rules:** deterministic (inject `clock` and `SIM_TODAY`, and seed the RNG with `SEED`); no network; no real time unless the test is about time (TOTP windows, circuit-breaker reset).

2.2 Integration tests — `test/integration/*.test.js`

- **Target:** application services wired through `createContainer(config)` with the **in-memory store** and sandbox gateways. Examples: `ingest` → `rebuild` → `profiles.rebuilt` event → `lead recompute` → touchpoints; `purchase` → `policy.issued` → confirmation message and cross-sell touchpoints; `rule approve` → `rules.activated` → cache invalidation.
- Faults are injected by replacing a gateway `port`, for example a wallet that throws `errors.upstream`, or a policy admin that fails on the second line.

2.3 API and contract tests — `test/api/*.test.js` (`npm run test:api`)

- **Target:** every route in `src/adapters/http/routes.js` (80 in release 1.0.0: 6 public, 60 staff, 10 customer, 4 partner; tests derive the list from the route table, so the count can change) over real HTTP. Each test starts `createHttpApp(container)` on an ephemeral port.
- **Contract:** `GET /api/openapi.json` is generated from the route table, so contract tests check that the document:
 - lists every route;
 - declares `security` per audience (`bearerAuth` or `partnerApiKey`);
 - marks `Idempotency-Key` as required on the two order routes (`/api/customer/orders`, `/api/partner/v1/orders`);
 - sets `additionalProperties: false` on request bodies.
- `npm run job -- openapi` writes `docs/api/openapi.json`. CI diffs it against the committed copy, and partners get a change notice when it differs (see Release and Change Management, `docs/operations/release-and-change-management.pdf`).
- **Authorisation matrix:** for every route × every role in `rbac.json`, the expected outcome (2xx, 401 or 403) is asserted table-driven from the `perm` field. The matrix covers every route × 15 roles (80 × 15 in release 1.0.0).
- **Negative paths:** 400 (validation, unknown property, malformed path parameter), 404, 405, 409, 413, 415, 422, 423 and 429.

2.4 Functional acceptance tests — `test/functional/*.test.js` (`npm run test:functional`)

- **Target:** the Given/When/Then scenarios of the user stories (User Stories and Acceptance Criteria, `docs/business/04-user-stories-and-acceptance-criteria.pdf`). There is **one automated test per scenario**, named `US-xxx · <scenario>`, running against the real API and services with the in-memory store and sandbox gateways.
- **Files:** `ep01-04-data-leads-journeys.test.js` (EP-01 to EP-04), `ep05-08-voice-sales-app-value.test.js` (EP-05 to EP-08) and `ep09-15-partners-claims-privacy-governance.test.js` (EP-09 to EP-15), with shared fixtures in `fx.js`.
- **Scope:** 124 scenarios: 121 automated and 3 recorded as `test.todo` because they are manual or roadmap items (US-055 fleet dashboard, which is `available:false`; US-076 language toggle and US-077 physical QR scan, which are verified in UAT).
- **Traceability:** each scenario is a row of the *Functional Test Cases* sheet of the results workbook, with its epic, story, persona, requirement (FR) and result.
- The functional suite also runs inside `npm test`, `npm run test:coverage` and `npm run test:security`.

2.5 System integration testing (SIT) — VETC, TASCO and Zalo sandboxes

Interface (port)	Counterparty environment	Key SIT scenarios	Prerequisite
PaymentGateway debit / refund	VETC wallet UAT	Debit idempotency on <code>orderId</code> ; timeout then retry returns the same <code>transactionId</code> ; refund after an issuance failure; insufficient balance → 4xx (non-retryable, so the breaker does not count it)	Real VETC wallet adapter, test wallets with balances
Customer SSO token exchange	VETC identity UAT	VETC SSO token → <code>POST /api/customer/session</code> ; expired token, wrong audience	Production verification in place of the sandbox <code>issueCustomerToken</code>

Interface (port)	Counterparty environment	Key SIT scenarios	Prerequisite
PolicyAdministration issuePolicy / cancelPolicy	TASCO core UAT	Issue TNDs car or motorbike, MOTOR_PD (after a recorded inspection) and PA_SEAT; certificate URL and QR; multi-line order with a failure on line 2 (saga compensation: line 1 cancelled, full refund)	TASCO core adapter, product mapping signed off
NotificationChannel zalo_zns	Zalo ZNS sandbox / OA test	Approved template IDs per templateKey; parameter mapping; delivery receipts	Zalo template approval (readiness item PRC-COMP-05)
NotificationChannel sms	SMS brandname test account	Brandname registered; Vietnamese diacritics and length	Brandname registration
NotificationChannel app_push	VETC app push (FCM/APNs) test project	Deep link .../app/?r=<signed>&j=<journey> opens one-tap renewal	VETC app build with deep-link handler
Telephony runCall	Voice - AI vendor test SIP trunk	ASR text turns into the dialogue engine; plate-first verification; opt-out; transfer to telesales	Vendor contract and test numbers
Ecosystem events	VETC event feed (staging)	vetc.tag_activated, vetc.inspection_booked, vetc.wallet_topped_up, vetc.long_trip_started → POST /api/ecosystem/events	Event feed or webhook relay
Batch extracts	VETC accounts and TASCO core policy extracts (masked)	POST /api/data/ingest with batches of ≤ 2,000 records (API maximum 5,000; 1 MiB body limit, KI-16); reject handling; lineage	Data-sharing agreement, masking pipeline

SIT runs on the **SIT environment** (Postgres, `DEMO_MODE=false`, real adapters pointing at partner UAT). Exit: all SIT cases P1/P2 passed, interface defects closed or waived by both parties (milestone M6, 08 January 2027).

2.6 User acceptance testing (UAT)

Business scenarios by persona: campaign manager, telesales agent and supervisor, rule author and approver, compliance officer, data steward, claims handler, partner manager, partner API consumer, customer (VETC app and Zalo), executive, auditor, admin and production support. The detailed plan, scenarios and sign-off sheet are in the [UAT Plan](#). The persona manuals in [docs/manuals/](#) are the step-by-step scripts.

2.7 Non-functional testing (NFT)

Type	Objective	Approach	Owner	Detail
Performance (load)	Meet the p95 SLOs at expected peak	<code>npm run test:perf</code> (test/perf/load.js, reports p50/p95/p99 and RPS); k6 optional for distributed load	Perf engineer	Performance plan \$5
Volume	6M vehicle profiles; incremental rebuild by plate; lead recompute at full scale	Synthetic generator at 6M (<code>SEED_RECORDS</code>), Postgres PERF environment	Perf engineer + Data	Perf plan \$5 PERF-S7-S9

Type	Objective	Approach	Owner	Detail
Stress	Find the breaking point and confirm graceful degradation (429 and 503, no 500 storm, no data corruption)	Ramp to 2–3× peak	Perf engineer	Perf plan PERF-S10
Soak	No memory growth or connection leaks over 8–24 h	Constant 60 % peak, watch <code>process_resident_memory_bytes</code>	Perf engineer	Perf plan PERF-S11
Security — SAST	Code-level flaws	CodeQL (CI), ESLint	DevSecOps	\$2.8
Security — dependencies	Known CVEs	<code>npm run audit (--omit=dev --audit-level=high)</code> , SBOM (CycloneDX)	DevSecOps	\$2.8
Security — secrets	No secrets in git	gitleaks (CI)	DevSecOps	\$2.8
Security — container	Image CVEs and misconfiguration	Trivy image + config scan (CI)	DevSecOps	\$2.8
Security — DAST	Runtime flaws	OWASP ZAP baseline against the freshly built image (CI, every push, report only); authenticated ZAP full scan before G3	DevSecOps	\$2.8
Security — abuse cases	IDOR, JWT tampering, lockout, MFA, rate limits, traversal, injection	<code>test/security/*.test.js</code> (<code>npm run test:security</code>)	QA + DevSecOps	Catalogue \$1, \$2, \$13
Penetration test	Independent assurance	Third-party test (grey-box, OWASP ASVS L2 scope) in UAT week T2	TASCO Security	Readiness PRC-SEC-08
Resilience / chaos	Circuit breakers, outbox retries, DB failover, pod loss	Fault injection (§2.9)	SRE	Catalogue \$14
DR	RPO/RTO achievable	Restore from PITR; regional failover drill	SRE + DBA	DR and BCP \$7
Accessibility	WCAG 2.2 AA	axe-core automated scan on every page + manual screen reader (NVDA/Windows, VoiceOver/iOS, TalkBack/Android) + keyboard-only	QA + UX	\$2.10
Usability	Agents and customers complete key tasks	Moderated sessions per the Usability Testing Plan (docs/ux/usability-testing-plan.pdf)	UX	UAT plan \$7
Localisation	Vietnamese is primary, English secondary	\$2.11	QA + TASCO Business	Catalogue \$15
Compliance	Regulatory controls in code and rules	\$2.12	QA + Compliance	Catalogue \$5, \$17
Data quality and reconciliation	Golden record and financial integrity	\$2.13	Data steward + QA	Catalogue \$3, \$12
Migration	Schema and data migrations safe and repeatable	\$2.14	DBA + QA	TC-110, TC-112, test/pg

2.8 Security testing

Control	Tool / test	Gate
Static analysis	CodeQL (javascript queries, security-extended)	No new high or critical alerts on the PR
Lint	npm run lint (ESLint 9 flat config)	Zero errors
Dependencies	npm run audit	No high or critical issues in production dependencies
SBOM	CycloneDX SBOM attached to each release	Generated for every tagged build
Secrets	gitleaks over the full history on PRs	Zero findings (false positives allow-listed with justification)
Container	Trivy image scan	Fails on high or critical findings; an exception needs a waiver with expiry
DAST	ZAP baseline (passive) in CI on every push against the built image (report only); authenticated active scan before G3	No high-risk alerts at release; mediums triaged
Abuse cases	test/security/*.test.js	All pass
Pen test	Independent vendor	No open critical or high findings at G3; mediums have a dated plan

Abuse-case coverage maps to concrete controls in the code:

Control in code	Abuse case IDs (catalogue)
verifyJwt rejects alg other than HS256, bad signature, expired, wrong audience; tokens issued before a password, role or status change are rejected (tokensValidAfter)	TC-013-TC-016, TC-011
Lockout after LOCKOUT_MAX_FAILURES (5) failures across password and TOTP steps, for LOCKOUT_MINUTES (15) → 423 ACCOUNT_LOCKED; TOTP replay rejected	TC-005, TC-006, TC-020
Login rate limit RATE_LIMIT_LOGIN_MAX (10/min per IP) → 429 with Retry-After: 60	TC-121
Global rate limit RATE_LIMIT_MAX (300/min per IP; certificate verification costs 2) → 429	TC-122
Body limit BODY_LIMIT_BYTES (1 MiB) → 413; non-JSON content type → 415	TC-118, TC-119
Static path traversal guard (file.startsWith(PUBLIC_DIR + sep))	TC-120
Allow-list validation (unknown property → 400)	TC-117
Parameterised SQL + assertColumns filter allow-list	TC-123, TC-124
Ownership checks on customer and partner quotes	TC-071, TC-081
Maker-checker	TC-090, TC-091
PII encryption at rest (AES-256-GCM) and log redaction	TC-108, TC-109

2.9 Resilience and chaos testing

Fault	Injection method	Expected behaviour (from code)
VETC wallet slow or down	Sandbox port with delay > 5 s or errors	Timeout 5 s, 2 retries with jittered backoff (<code>baseDelayMs 100</code>), circuit opens after 5 consecutive failed calls and short-circuits for 30 s (<code>integration_short_circuit_total{integration="vetc-wallet"}</code>); order goes to <code>payment_failed</code> and the quote is released; API returns 503 <code>UPSTREAM_UNAVAILABLE</code>
TASCO core down after capture	Policy admin port throws	Saga compensation: lines already issued are cancelled (<code>cancelPolicy</code>) and the full amount is refunded through the <code>vetc-wallet</code> breaker; order <code>issuance_failed_refunded</code> , or <code>compensation_failed</code> if a cancellation or the refund fails (flagged by reconciliation); <code>orders_compensation_total{status}</code> ; <code>audit order.issuance_failed</code>
Zalo ZNS or SMS down	Notification port throws	Message stored <code>status:"failed"</code> ; the next channel in the step is tried; <code>messages_total{status="failed"}</code> rises
Voice-AI down	Telephony port throws	Breaker <code>voice-ai</code> (timeout 30 s, no retries); touchpoint execution errors
Event handler failure	Subscriber throws	Event goes back to pending, attempts increments; after 5 attempts → <code>dead_letter</code> ; <code>events_processed_total{status="dead_letter"}</code>
Process crash mid-relay	<code>kill -9</code> during relay	Postgres: events left in processing are re-claimed after 5 min and handlers already completed (<code>handled[]</code>) are skipped; in-memory store: no re-claim (dev only)
Postgres primary failover	Managed failover / <code>pg_terminate_backend</code>	<code>/health/ready</code> → 503 while <code>SELECT 1</code> fails; pool reconnects; no 500 storm after recovery
Pod termination	<code>kubectl delete pod</code> under load	<code>SIGTERM</code> → <code>readiness false</code> → server closes in ≤ 25 s → exit 0; no failed in-flight requests if <code>terminationGracePeriodSeconds</code> ≥ 30
Replica scale-out during relay	3 replicas relaying	Postgres <code>FOR UPDATE SKIP LOCKED</code> prevents double claim; handlers are idempotent

2.10 Accessibility (WCAG 2.2 AA)

- **Automated:** axe-core scan of every staff console page, the customer app and `/verify/<certNo>`, in light and dark themes and in `vi` and `en`. Zero serious or critical violations.
- **Manual:** keyboard-only pass (focus order, visible focus, no traps, 2.4.11 *Focus Not Obscured*); screen readers NVDA + Firefox, VoiceOver + iOS Safari and TalkBack + Android Chrome on the customer app; 2.5.8 *Target Size* (24×24 CSS px minimum) on the mobile app; 3.3.8 *Accessible Authentication* (MFA allows paste and password managers); status messages announced (quote ready, payment result).
- **Content:** Vietnamese diacritics read correctly (`lang="vi"`); currency read as "đồng".

2.11 Localisation (vi / en)

- Customer-facing copy is Vietnamese-first. `content.messages.json` and `content.voicebot.json` carry `vi` (sent) and `en` (staff review gloss).
- Tests check that placeholders resolve (`{{plate}}`, `{{expiry}}`, `{{premium}}`, `{{link}}`, `{{benefit}}`, `{{days}}`), that dates print as `dd/mm/yyyy` (`viDate`), that currency prints in the `vi-VN` locale with `đ`, and that SMS length after diacritics stays within the agreed segment count.
- The voice bot keyword NLU uses diacritic-stripped matching (`stripDiacritics`). Tests use both accented and unaccented utterances.

2.12 Compliance testing

Control	Source of truth	Test focus	Catalogue
Copy guard (no discount, rebate or cashback wording for price-regulated products)	<code>copy_guard.json</code> ; <code>validatePayload</code> on content and benefits; <code>checkCopy</code> at send time	Draft with banned phrase rejected (with and without diacritics, and with whitespace or punctuation evasions such as "giảm giá" or "cash back"); runtime block → <code>status:"blocked"</code>	TC-060, TC-061, TC-095
Contact window 08:00–20:00 ICT (UTC+7) for marketing	<code>contact_policy.json</code> , <code>inContactWindow</code>	Boundary values 07:59, 08:00, 19:59, 20:00 ICT	TC-050–TC-052
Consent (marketing, call) and DNC	<code>consentRequired</code> , <code>consent.dnc</code>	No marketing without consent; no calls without <code>call</code> consent; DNC suppresses everything	TC-053–TC-055
Frequency caps	1 per day and 3 per week for marketing; 2 call attempts per week	Cap boundaries; service messages bypass caps (<code>serviceMessagesBypassCaps</code>)	TC-056–TC-058
Maker-checker and separation of duties	<code>rulesService.approve/reject</code> ; <code>rbac.json</code> <code>separationOfDuties</code> (e.g. <code>rule_author</code> + <code>rule_approver/compliance_officer</code> , <code>admin</code> + <code>business</code> roles cannot be combined) and <code>restrictedRuleKinds</code> (<code>abac</code> , <code>copy_guard</code> , <code>contact_policy</code> , <code>commission</code> and <code>retention</code> need a <code>compliance_officer</code> to approve)	Author cannot approve or reject own draft; only the author can submit; conflicting role combinations refused; restricted kinds refused for a <code>rule_approver</code>	TC-090–TC-092, TC-027
Commission caps	<code>commission.json</code> <code>statutoryCaps</code> ; <code>validator</code> + <code>runtime commissionFor</code>	Draft above cap rejected; runtime caps applied	TC-084, TC-085
PII masking and minimisation	<code>maskProfile</code> , <code>profile:read_pii</code> , <code>handoff</code> <code>summary</code> , public certificate verification	Masked for roles without PII permission; certificate verification shows masked plate and no name	TC-031, TC-074
Benefits pending legal review	<code>benefits.json</code> <code>legalStatus</code> , <code>benefitsFor(audience)</code>	<code>loyalty_points</code> never reaches customers; staff see it flagged	TC-041
Data subject rights	<code>/api/dsar/*</code> , <code>/api/customer/data-export</code> <code>rights</code>	Export complete; erasure blocked while a policy is active	TC-105–TC-107
Voice bot disclosure and plate-first	<code>content.voicebot.json</code> , <code>voicebot.js</code>	Bot never reads the full plate; discloses automation; opt-out honoured	TC-064–TC-069
Staff never take payment	<code>salesService.purchase</code> (customer actor only, or partner-collected)	Staff cannot debit a wallet; assisted sales send the quote to the customer's app	TC-156, TC-157
No time override in production	<code>at / date</code> parameters on journeys and voice campaign are honoured only when <code>DEMO_MODE=true</code>	Contact window evaluated on the real clock (KI-33 fixed)	TC-162

2.13 Data quality and reconciliation testing

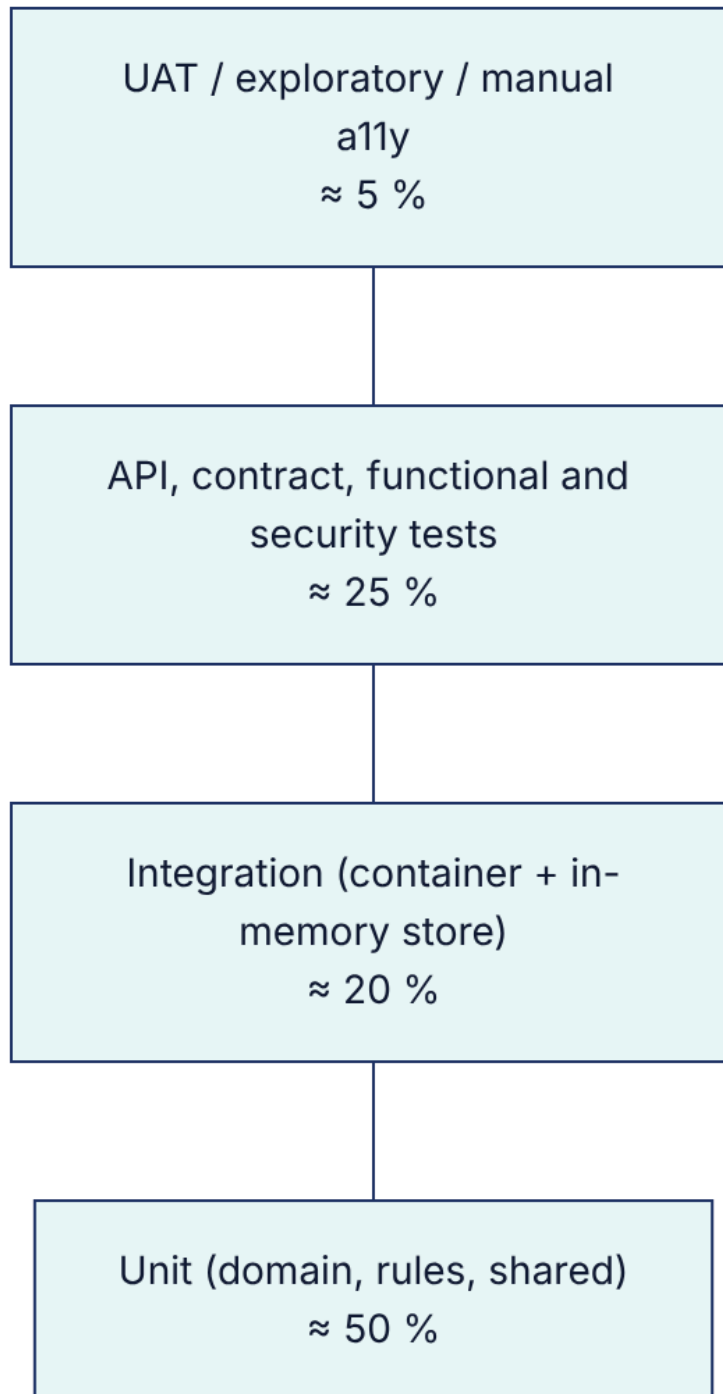
- **Golden record:** survivorship by `sourceTrust`, expiry inference by evidence weight, corroboration boost, and protection of `customer_declared`, `voice_bot` and `tasco_issued` facts against later rebuilds (`ingestionService.rebuild`).
- **DQ issues:** `invalid_plate`, missing fields, `conflicting_phone`, `wrong_person` and `plate_mismatch` raised once, and re-raised only after resolution.
- **Reconciliation:** `POST /api/ops/jobs/reconciliation` (or `npm run job -- reconcile`) flags completed orders without a payment reference or with a missing policy, orders stuck in `pending_payment` for more than 1 h, `compensation_failed` orders (manual action) and `payment_failed` orders (check with the VETC wallet that no capture occurred). Reconciliation SIT also compares against VETC wallet settlement files and TASCO core issuance reports. The comparison is manual until a settlement adapter exists (KI-18).
- **Counts:** after each ingest batch, `records = upserted source_records`, `rejected = invalid_plate DQ issues` (the response reports the correct rejected count), and `profilesTouched = distinct valid plate keys`.

2.14 Migration testing

- `db/migrations/*.sql` is applied by `store.migrate()` in a transaction per file, recorded in `schema_migrations`. Tests:
 1. Fresh database: all migrations apply.
 2. Re-run is a no-op.
 3. Schema parity: every collection, index column and blind-index column in `schema.js` exists in the SQL (`test/unit/platform.test.js`, "schema drift guard").
 4. Upgrade from the previous release's schema with production-like volume (PERF environment) within the maintenance budget.
 5. **Applied migration files are immutable.** A change to a file already on `main` is rejected in DBA code review (Release and Change Management §6); an automated CI check is recommended.
 6. Concurrency and integrity: two migrators started together are serialised by advisory lock 724002, and the objects from `002_integrity_hardening.sql` exist (one active rule set per kind; `audit_log` TRUNCATE blocked).
 - **Data migration (initial load):** the pilot cohort and later the full 6M base are loaded through `POST /api/data/ingest` or a batch job using the same `ingestionService`. Counts and samples are reconciled against source extracts (catalogue TC-112).
-

3. Regression and automation strategy

3.1 Test pyramid (target distribution)



3.2 CI gates (`.github/workflows/ci.yml`)

Gate	Command / tool	Blocking on PR	Blocking on release tag
Lint	<code>npm run lint</code>	Yes	Yes

Gate	Command / tool	Blocking on PR	Blocking on release tag
Unit, integration, API, security and functional suites with coverage	<code>npm run test:coverage: lines ≥ 80 %, functions ≥ 80 %, branches ≥ 70 % (excludes src/jobs/cli.js, src/server.js and postgresStore.js, which test:pg covers)</code>	Yes	Yes
OpenAPI contract	<code>node src/jobs/cli.js openapi then git diff --exit-code docs/api/openapi.json</code>	Yes	Yes
PostgreSQL tests	<code>npm run test:pg</code> against a PostgreSQL 16 service container (TEST_DATABASE_URL)	Yes	Yes
Perf smoke	<code>npm run test:perf</code> (in-process server, 15 s, 25 concurrent): $p95 \leq 300$ ms (P95_BUDGET_MS) and errors ≤ 1 %	Yes	Yes
CodeQL	GitHub CodeQL	Yes (new high/critical)	Yes
Dependency audit	<code>npm audit --omit=dev --audit-level=high;</code> dependency review on PRs	Yes	Yes
Secrets	gitleaks	Yes	Yes
Container	Trivy image scan	Yes (high/critical)	Yes (high/critical)
SBOM	CycloneDX	—	Yes (artefact)
DAST	ZAP baseline against the built image	No (report only)	Yes (no high, reviewed by DevSecOps)

3.3 Regression approach

- **Every PR:** full automated suite. It runs in minutes because the in-memory store needs no infrastructure.
- **Rule changes** go through maker-checker, not code release. The rules studio's `POST /api/rules/validate` and `POST /api/rules/simulate` are the regression tools for business rules. A rule change that affects scoring, NBA, journeys or benefits must include a simulation on a reference set of profiles (listed in the UAT plan) as approval evidence.
- **Release candidate:** automated suite + SIT smoke (wallet debit and refund, issue, ZNS send, SSO) + targeted manual regression of the changed area.
- **Defect-driven tests:** every fixed defect of Sev 1–2 gets an automated regression test that references the defect ID in the test name.

4. Environments

Env	Purpose	Store	DEMO_MODE	Integrations	Data	Access
LOCAL / CI	Dev and automated tests	In-memory (Postgres service for test:pg)	true (tests choose)	Sandbox adapters	Synthetic (SEED=20261007)	Developers, CI
DEV	Integration of features	Postgres	true	Sandbox	Synthetic 2,500–50,000 records	Delivery team
SANDBOX (demo)	Stakeholder demos	Postgres or memory	true	Sandbox	Synthetic	Stakeholders (no real data)
Hosted UAT (Railway)	Business walkthroughs and early UAT at https://tasco-growth-api-uat.up.railway.app	PostgreSQL	true (NODE_ENV=uat)	Sandbox adapters	Synthetic; demo accounts kept usable by DEMO_ACCOUNT_SYNC and DEMO_TOTP_SEED	Named testers (access workbook)
SIT	Integration with partners	Postgres	false	Real adapters → VETC, TASCO and Zalo UAT	Synthetic + partner test accounts	Delivery + partner IT
UAT	Business acceptance	Postgres	false (named accounts; the seed job refuses to run without DEMO_MODE)	Real adapters → partner UAT	Synthetic and masked samples; no production PII	Business users (named)
PERF	Load, volume, soak, stress	Postgres sized like PROD	false	Sandbox adapters with latency injection	Synthetic 6M profiles	Perf team
PREPROD	Release rehearsal, DR drills	Postgres (PITR)	false	Partner UAT/prod-like	Synthetic	Ops
PROD	Live	Postgres HA (PITR)	false (startup refuses DEMO_MODE unless ALLOW_DEMO_IN_PRODUCTION)	Production adapters	Real	Least privilege

Production configuration guards that are tested (`shared/config.js` , `test/unit/platform.test.js`): with `NODE_ENV=production` , the process refuses to boot without `JWT_SECRET` , `BLIND_INDEX_KEY` , `DATA_KEYS` and `DATABASE_URL` (no in-memory store in production), and with `DEMO_MODE=true` . `DEMO_MODE` defaults to false everywhere. `DATABASE_SSL` and `TRUST_PROXY` default to on in production.

5. Test data management

- **Synthetic first.** `syntheticVetcSource.generate({ count, seed, today })` reproduces the real data problems: about 1 in 10 verified policies, dirty plates and phones, duplicates across sources, and partner-owned policies. It is deterministic per `SEED` . Use `SEED_RECORDS` to size it (2,500 by default; 6,000,000 for volume tests in batches).
- **No production PII outside PROD.** SIT and UAT use synthetic profiles and partner-issued test identities (test wallets, test SIM numbers for voice and SMS, test Zalo accounts). Production extracts used for data profiling during Discovery are masked: names replaced, phones replaced with the synthetic generator, plates kept only where needed and only in the PERF/UAT environments under a data-sharing agreement.
- **Time control.** `SIM_TODAY` pins the business date, so journey tests (offsets -45 to 0 days) and quote expiry (24 h TTL) are reproducible.
- **Demo users** (`seed.js`): 14 staff users covering the 13 staff roles (two telesales agents, for Hà Nội and TP. Hồ Chí Minh), with MFA for `admin` , `approver` , `compliance` and `steward` . They exist **only** where `DEMO_MODE=true` (LOCAL, DEV, SANDBOX and the hosted UAT); the `seed` job refuses to run otherwise. Locally the demo password defaults to `Tasco@Demo2026!` ; the hosted UAT overrides it with `DEMO_PASSWORD` and the testers receive it in the access workbook (it is never written in documents). `DEMO_TOTP_SEED` publishes authenticator keys for the MFA demo users, and `DEMO_ACCOUNT_SYNC=true` unlocks and resets the demo accounts at start-up. The demo TOTP helper `GET /api/demo/totp/:username` is `demoOnly` and returns 404 when `DEMO_MODE=false` (TC-012).
- **Reset.** `store.reset()` (tests), or dropping and re-creating the database followed by `npm run migrate` and `npm run seed` (lower environments with `DEMO_MODE=true` only).

6. Entry and exit criteria

Level	Entry	Exit
Unit / integration / API	Story in progress; acceptance criteria defined	All pass; coverage gate met; no lint errors
SIT	Build complete (G2); production adapters deployed to SIT; partner UAT endpoints and credentials available; IIAs signed	100 % of P1 and ≥ 95 % of P2 SIT cases passed; no open Sev 1/2 interface defects; reconciliation proven end to end
UAT	SIT exit met; UAT environment loaded; users trained; persona scripts issued	See the UAT Plan §4 : business sign-off sheet complete
NFT	Feature-complete build in PERF; monitoring in place	SLOs met (Performance and Capacity Test Plan §8); soak shows no leak; DR drill within RPO/RTO
Security	Feature-complete build	No open critical/high (SAST, DAST, dependencies, container, pen test); mediums with dated plan
Go-live (G3)	All of the above	Production Readiness Checklist all "Done" or waived by SteerCo

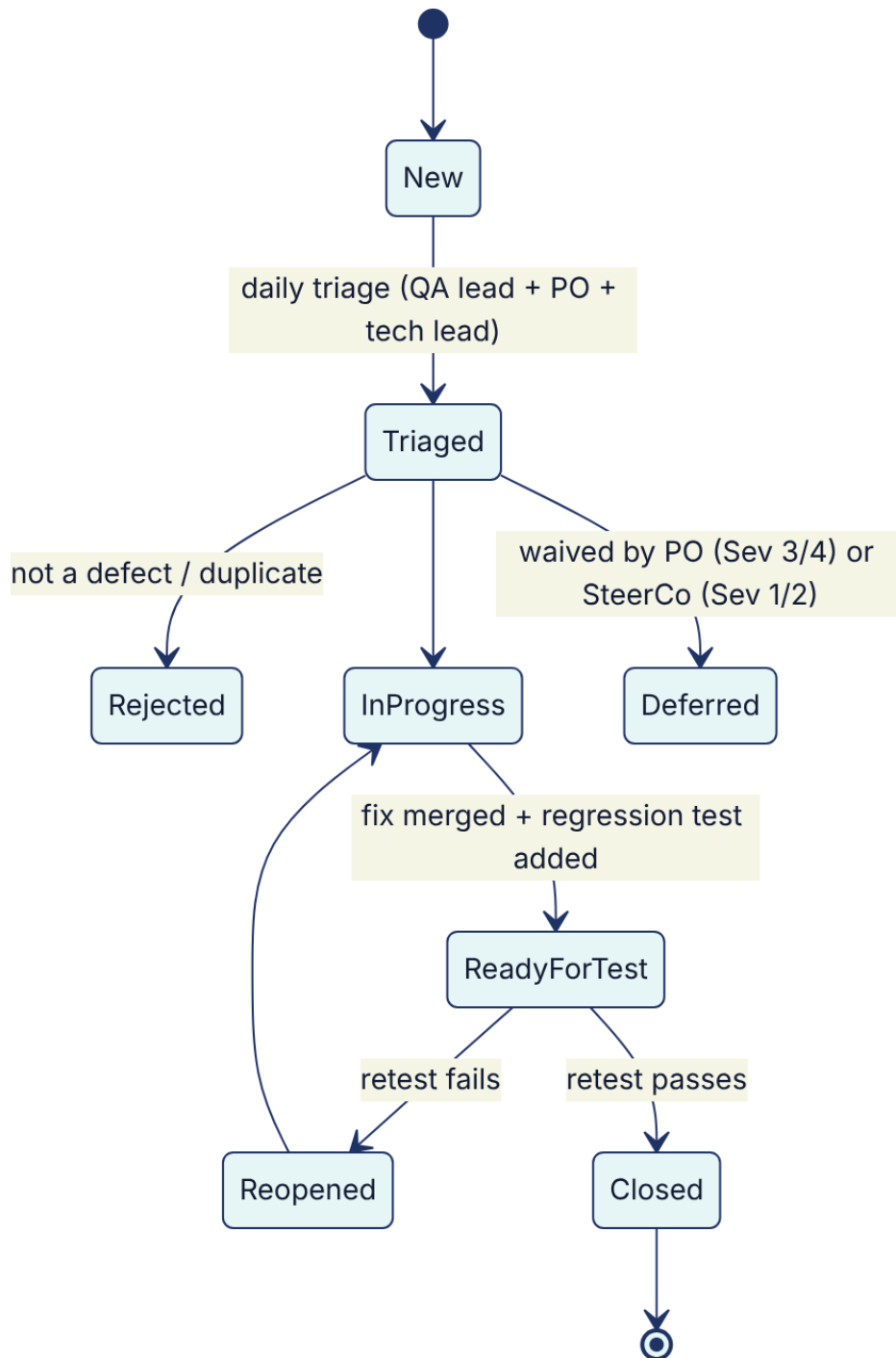
7. Defect management

7.1 Severity definitions

Severity	Definition	Examples in this system	Fix expectation (test phases)
Sev 1 — Critical	Data loss, security breach, regulatory breach, money taken without cover, or a core flow down with no workaround	Customer charged and no policy (and no refund); PII exposed to unauthorised role; message with discount wording sent to customers; contact with DNC customer; audit chain cannot be verified; maker approves own rule	Fix before the next build; blocks the gate
Sev 2 — High	Major function broken, workaround exists but costly; compliance risk	Journeys skip a whole cohort; partner commission wrong; voice bot opt-out not persisted; lockout not enforced	Fix before gate exit
Sev 3 — Medium	Function impaired, reasonable workaround	Lead filter wrong; dashboard count off; 500 instead of 400 on malformed input	Fix or plan before go-live; can be waived
Sev 4 — Low	Cosmetic or minor	Label typo, minor layout issue	Backlog

Priority (P1–P4) is set separately by the Product Owner for business urgency.

7.2 Workflow



Each defect records: environment, build/commit, `X-Request-Id` (the API returns it in every response and every error body), route, persona, steps, expected/actual, severity, priority, and for data defects the profile id (never PII in the ticket).

8. Metrics

Metric	Target
Automated pass rate on <code>main</code>	100 % (flaky tests quarantined within 24 h)
Coverage (lines / functions / branches)	≥ 80 / 80 / 70 % (gate)

Metric	Target
Requirements → test traceability	100 % of MVP stories have ≥ 1 test case
Defect detection percentage (pre-prod vs total, 30 days after go-live)	≥ 90 %
Open Sev 1/2 at gate	0
Defect reopen rate	< 10 %
Mean time to fix Sev 1 / Sev 2 (test phases)	< 1 day / < 3 days
SIT pass rate (P1)	100 %
a11y serious/critical violations	0

9. Roles and responsibilities

Role	Organisation	Responsibilities
QA Lead	iorta TechNXT	Owens this strategy, catalogue, triage, reporting, gate evidence
Test engineers (2)	iorta TechNXT	Automated suites (test/*), SIT execution, regression
Performance engineer	iorta TechNXT	Perf, volume, soak, stress; capacity model
DevSecOps engineer	iorta TechNXT	CI security gates, ZAP, Trivy, pen-test coordination
SRE	iorta TechNXT → TASCO IT (BAU)	Resilience and DR tests, monitoring
Product Owner	TASCO	Acceptance criteria, defect priority, UAT coordination
Business testers	TASCO (telesales, campaign, claims, partners), VETC (app, CX)	UAT execution and sign-off
Compliance officer	TASCO	Compliance test sign-off: copy guard, contact policy, consent, scripts, benefits
Data steward	TASCO	Data-quality acceptance, reconciliation sign-off
VETC IT / TASCO core IT / Zalo account manager	Partners	SIT endpoints, test data and accounts, interface defect fixing
Independent pen tester	Third party	Penetration test and report

10. Current execution results

The latest full execution ran on 07 October 2026 on release 1.0.0 (Node.js 22, PostgreSQL 16 for `test/pg`, in-memory store for the other suites). The record of execution, with one row per test case, per functional scenario and per automated test, is the workbook **TASCO-Test-Cases-and-Results.xlsx** (docs/quality/TASCO-Test-Cases-and-Results.xlsx).

Measure	Result	Gate
Automated tests (node:test)	238 tests: 235 passed, 0 failed, 3 todo (the three manual/roadmap functional scenarios)	0 failed

Measure	Result	Gate
Functional acceptance scenarios (test/functional)	124 scenarios: 121 automated and passing, 3 manual/roadmap	All automated scenarios pass
Coverage (lines / branches / functions)	99.5 % / 91.6 % / 97.2 %	≥ 80 % / ≥ 70 % / ≥ 80 %
Lint (ESLint)	0 errors	0 errors
Load smoke (test/perf/load.js, 1 process, 25 concurrent, 15 s)	≈ 337 req/s, p95 ≈ 103 ms, 0 % errors	p95 ≤ 300 ms, errors ≤ 1 %
PostgreSQL suite (test/pg/postgres.test.js)	Migrations, encryption at rest, injection resistance, audit immutability, one active rule version per kind, SKIP LOCKED outbox claims and an end-to-end sale: all pass	All pass

Test layout in the repository:

Folder	Content
test/unit	identity, jsonLogic, platform, rulesDomain, stores, voicebot
test/integration	governance, journeys, sales
test/api	api.test.js (HTTP, contract, authorisation matrix)
test/security	security.test.js (OWASP-style abuse cases and hardening regressions)
test/functional	Three epic files with one test per user-story scenario (124)
test/pg	postgres.test.js (PostgreSQL adapter, needs TEST_DATABASE_URL)
test/perf	load.js (dependency-free HTTP load generator)

The SIT, UAT, DR and accessibility cases of the catalogue are not executed by the automated run. The workbook records them as *Not Run* or *Blocked* until their phase (see the catalogue).

Appendix A — Known issues register (from code review, 07 October 2026)

These items were found while deriving the tests. Each one was logged as a defect with the proposed severity and is referenced by test cases, runbooks and the readiness checklist. IDs are stable. Statuses were re-verified against the release 1.0.0 code on 07 October 2026; the QA Lead re-verifies them at each release. **17 items are fixed** (KI-01, 02, 05, 06, 09, 11, 14, 15, 25, 26, 27, 28, 29, 30, 31, 32 and 33); **16 remain open**, some of them partly fixed.

ID	Sev (proposed)	Area	Finding	Evidence	Recommendation / fix	Status
KI-01	1	Security	npm run job -- seed was not guarded by DEMO_MODE; run against a production database it would create 14 demo users with the published demo password	src/jobs/cli.js JOBS.seed	The seed job now throws unless DEMO_MODE=true; DEMO_MODE defaults to false and production refuses to start with it; no seed CronJob in deploy/k8s	Fixed
KI-02	1	Sales	When issuance failed after line 1 of a multi-line order, the full amount was refunded but issued policies stayed active; refund errors were swallowed and bypassed the circuit breaker; reconciliation ignored failed orders	salesService.purchase; opsService.reconcile	Saga compensation: issued lines are cancelled (cancelPolicy) and the full amount refunded through the vetc-wallet breaker; order issuance_failed_refunded, or compensation_failed when a cancellation or refund fails; reconciliation flags compensation_failed and payment_failed; orders_compensation_total. Partner orders are partner-collected (no wallet refund). See RB-11	Fixed
KI-03	3	Events	Events left in processing by a crashed replica are now re-claimed after 5 minutes by the PostgreSQL store (not the in-memory store). dead_letter events still have no replay tool : the relay only claims pending	claimEvents; outboxEventBus.relay	Add an ops endpoint or job to requeue dead letters; interim SQL in RB-06	Open (partly fixed)
KI-04	2	Performance	HTTP handlers call c.events.drain() inline (orders, partner quotes, ingest, voice turns, consent, expiry, journeys run, ecosystem events). drain processes the global backlog , so one request's latency depends on everybody's events	routes.js	Drain only the events published by the request, or rely on the background relay; PERF-S5 measures the impact	Open
KI-05	2	Journeys	runDue handled at most 5,000 touchpoints per run and marked window-blocked touchpoints skipped permanently	journeyService.runDue	runDue now pages through all due touchpoints; touchpoints blocked only by the 08:00–20:00 window are deferred (stay scheduled, counted as deferred); the journeys CronJob runs at 01:15 UTC (08:15 ICT). Throughput of sequential sends at peak is tracked in the capacity model	Fixed
KI-06	—	Security	POST /api/auth/mfa did not check lockedUntil or status, so a holder of a valid mfaToken could keep guessing codes	identityService.verifyMfa	verifyMfa checks status and lock, counts failures across both factors and rejects TOTP replay (lastTotpStep); regression TC-020	Fixed
KI-07	3	Security / scale	Token revocation (logout) and rate limiting are in-process per replica. With N replicas the effective limits are N×, and a logged-out token stays valid on other replicas until exp (30 min)	identityService.revocation map; security.createRateLimiter	Shared cache (Redis) or gateway/WAF rate limits (the ingress applies a shared edge limit); short JWT TTL	Open

ID	Sev (proposed)	Area	Finding	Evidence	Recommendation / fix	Status
KI-08	4	Security	Signed renewal links expire (LINK_TTL_DAYS, default 30) but are keyed from JWT_SECRET, so rotating the JWT secret invalidates every link already sent	container.js links	Separate LINK_KEY	Open (partly fixed)
KI-09	1	Compliance	POST /api/voice/campaign checked only call consent, DNC, phone and owner type, bypassing the contact window and call caps	routes.js voice campaign; voiceService.canCall	Each call goes through voice.canCall (consent, DNC, window, caps), is recorded as a marketing contact and returns skipped reasons; regression TC-135	Fixed
KI-10	3	Access control	ABAC region checks apply to GET /api/customers/:id, its lineage, PATCH /api/customers/:id/expiry and POST /api/quotes/:id/send, but not yet to POST /api/voice/sessions, GET /api/voice/sessions/:id, GET /api/policies?profileId= and GET /api/claims. The ABAC policy customer_self is defined but unused	routes.js, abac.json	Apply access.check consistently; remove or use customer_self	Open (partly fixed)
KI-11	—	API	A malformed percent-encoding in a path parameter returned 500	router.match, app.js	The router returns 400 "Malformed path parameter"; regression TC-129	Fixed
KI-12	3	Performance	Full scans: GET /api/audit/verify loads the whole audit_log; insights.sumOrders, leads.recompute(all) and ops.reconcile page with OFFSET (O(n²) at 6M rows)	postgresStore.audit.verify, insightsService, leadService, opsService	Incremental verification checkpoint; keyset pagination; SQL aggregates	Open
KI-13	2	Compliance	Retention executes only source_records and voice_sessions deletes. Profile anonymisation and message, order and certificate archival are delegated to an archival pipeline that does not exist yet; domain_events, job_runs and quotes have no retention rule	opsService.applyRetention, retention.json	Build the archival job, or record a legal waiver before go-live	Open
KI-14	4	Security	/metrics was open to anyone who could reach the pod	app.js	/metrics requires Authorization: Bearer <METRICS_TOKEN> when METRICS_TOKEN is set (regression in test/security); set it in every environment and keep /metrics blocked at the ingress. /api/openapi.json is public by design	Fixed

ID	Sev (proposed)	Area	Finding	Evidence	Recommendation / fix	Status
KI-15	—	Front-end	public/ lacked index.html, app/ and verify.html, so /verify/<certNo> (the QR target) returned 404	public/	The UX workstream added the pages; confirm in the release image (PRC-FUNC-04, SYN-09)	Fixed
KI-16	4	API	POST /api/data/ingest allows 5,000 records but the body limit is 1 MiB, so large batches get 413	routes.js, config.bodyLimitBytes	Use batches of ≤ 2,000 records, or raise the limit per route	Open
KI-17	4	Observability	/metrics has no # TYPE/# HELP lines and no gauges for circuit state, outbox backlog or DB pool; counters are per process and reset on restart	shared/metrics.js	Add gauges; alert rules use rate()/increase() (Monitoring and Alerting)	Open
KI-18	2	Sales	A wallet debit that times out on our side but is captured by VETC leaves the order in payment_failed with no refund; there is no settlement-file reconciliation adapter	salesService.purchase	Daily settlement reconciliation against the VETC statement; reconciliation now flags every payment_failed order for a check (RB-11)	Open
KI-19	3	Security ops	DATA_KEYS rotation works for new writes but there is no re-encryption job , so old key IDs must be kept indefinitely. BLIND_INDEX_KEY cannot be rotated without rebuilding phone_bidx (no tooling)	shared/crypto.js, codec.js	Build a re-encrypt/re-index job; see SOP-01	Open
KI-20	4	Sales	Two concurrent purchases with the same Idempotency-Key race on orders.insert; the loser gets 409 CONFLICT instead of an idempotent replay. A sequential retry of a completed order replays correctly, and concurrent purchases of one quote cannot double-charge (the quote is claimed atomically as paying)	salesService.purchase	Return the stored order on conflict	Open
KI-21	4	Rules	The commission validator checks caps only for rules whose when names the product literally; runtime commissionFor still caps (flag capped). Products absent from statutoryCaps get a 0 % cap	validators.js commission; rating.commissionFor	Validate every product × partner type combination	Open
KI-22	4	Security	The request body is read and parsed before authentication, so an unauthenticated caller can make the server buffer up to 1 MiB; a wrong content type returns 415 before 401	app.js handle order	Authenticate before reading the body for non-public routes	Open

ID	Sev (proposed)	Area	Finding	Evidence	Recommendation / fix	Status
KI-23	4	Security	Customer tokens (1 h) cannot be revoked by the customer (no customer logout). Erased data subjects lose their sessions	<code>customerService.issueCustomerToken</code>	Add revocation, or a short TTL with refresh	Open
KI-24	4	Rollout	Journey audiences can target region, category and other facts, but no fact supports a percentage cohort, so a "% of base" rollout needs a code change	<code>domain/Leads.factsFor</code>	Add a <code>cohortBucket</code> fact (0–99)	Open
KI-25	2	Voice bot	<code>extractPlateFromSpeech</code> could not parse Vietnamese tens words, although the bot's <code>plateRetry</code> line tells customers to say "ba mươi A, một hai ba bốn năm"	<code>domain/identity.js</code> , <code>content.voicebot.json</code>	The parser now handles tens ("ba mươi" → 30, "năm mươi mốt" → 51) and motorbike plates (e.g. 59X1-123.45); regression in <code>test/unit/identity.test.js</code> ; SIT with real ASR remains (TC-154)	Fixed
KI-26	3	Compliance	The copy guard matched substrings literally, so whitespace and punctuation variants ("giảm giá", "cash back", "chiết-khấu") passed	<code>contactPolicy.checkCopy</code> , <code>validators.copyViolations</code>	Text is also compared with whitespace, dots, hyphens and underscores removed; regression in <code>test/integration/sales.test.js</code>	Fixed
KI-27	3	Identity ops	There was no admin API to unlock an account or reset MFA, so support needed direct database changes	<code>routes.js</code> , <code>identityService.reset</code>	POST <code>/api/users/:id/reset {unlock, resetMfa}</code> (users:manage, audited as <code>user.reset</code> , never reveals the seed; an admin cannot reset their own account); the user re-enrols at the next sign-in (SOP-08). Forgotten passwords are handled by the TASCO IdP once federated (ADR-007) or by SOP-08	Fixed
KI-28	1	Configuration	With <code>NODE_ENV=production</code> and no <code>DATABASE_URL</code> , the server booted on the in-memory store, losing all data on restart	<code>shared/config.js</code>	Production refuses to start without <code>DATABASE_URL</code> ("DATABASE_URL is required in production"); regression in <code>test/unit/platform.test.js</code> ; readiness still reports <code>store</code> (PRC-OPS-02)	Fixed
KI-29	—	Privacy	DSAR erasure skipped handoffs and claims	<code>customerService.erase</code>	Erasure also clears handoff name, masked phone and notes, claim description and location, and voice-session signals; erased subjects lose their sessions; regression TC-107. Quotes keep the plate (not PII on its own; Legal to confirm)	Fixed
KI-30	—	Deployment	Concurrent <code>MIGRATE_ON_START</code> on several replicas raced on <code>schema_migrations</code>	<code>postgresStore.migrate</code>	<code>migrate()</code> takes advisory lock 724002; Kubernetes keeps <code>MIGRATE_ON_START=false</code> and runs the migration Job before rollout	Fixed

ID	Sev (proposed)	Area	Finding	Evidence	Recommendation / fix	Status
KI-31	3	Sales	Re-sending a purchase with the same Idempotency-Key after a failure returned HTTP 200 with the failed order, so a client checking only the HTTP status showed success	<code>salesService.purchase</code>	A replay of a failed attempt now returns 409 CONFLICT ("A previous attempt with this Idempotency-Key ended as ... — retry with a new key"); the quote is released, so a new key succeeds; regression in <code>test/integration/sales.test.js</code>	Fixed
KI-32	4	Access control	POST <code>/api/quotes/:id/send</code> marked the quote as sent and wrote the audit entry before the ABAC region check	<code>routes.js</code> quote send	The region check now runs before <code>sales.markSent</code> , so an out-of-region agent gets 403 with no side effect (TC-158)	Fixed
KI-33	2	Compliance	POST <code>/api/journeys/run</code> and POST <code>/api/voice/campaign</code> accepted an <code>at</code> timestamp that replaced the real clock for the contact-window check	<code>routes.js</code> journeys run and voice campaign	<code>date</code> and <code>at</code> are honoured only when <code>DEMO_MODE=true</code> ; production always uses the real clock (TC-162)	Fixed